Gobierno de la Ciberseguridad y Análisis de Riesgos

Tema 9. Evaluación de riesgos de Tecnologías de la Información

Índice

Esquema

Ideas clave

9.1. Introducción y objetivos

9.2. Evaluación de riesgos de las Tecnologías de la Información

9.3. Referencias bibliográficas

A fondo

Modelado de amenazas, una técnica de análisis y gestión de riesgo asociado a software y aplicaciones

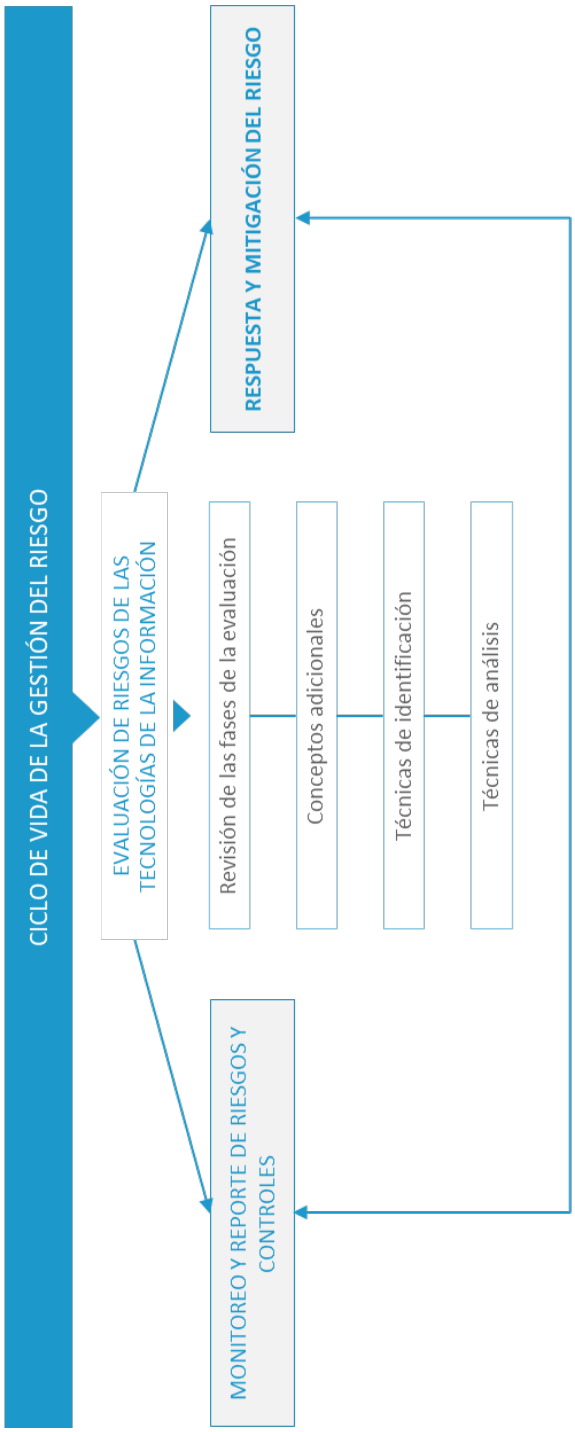
Caso práctico sobre apetito del riesgo

Patrones de Ataque y de Seguridad como guía en el desarrollo de software

Amenazas Persistentes Avanzadas

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

9.1. Introducción y objetivos

El objetivo fundamental de este tema es conocer las distintas actividades y tareas para la evaluación de riesgos en las Tecnologías de la Información (o TI).

Este tema abordará distintas cuestiones relativas a la evaluación de riesgos en las TI, profundizando en algunos aspectos relevantes.

Ciclo de vida de la gestión del riesgo

Para una adecuada gestión del riesgo es necesario implantar un proceso cíclico de evaluación y tratamiento del riesgo.

Los cambios en el entorno externo e interno de la organización hacen que el riesgo al que está expuesta sufra variaciones, al igual que el grado de eficiencia y la eficacia de las acciones de tratamiento del riesgo también sufren variaciones a lo largo del tiempo.

El **grado de variabilidad de los factores** que influyen en la estimación del riesgo es muy alto cuando hablamos de riesgos asociados a la seguridad de la información y de los sistemas de información que la procesan, almacenan o transmiten, y por lo tanto si no se revisa la evaluación inicial, con el tiempo la estimación del riesgo no reflejará la situación actual.

Si la estimación del riesgo actual no es correcta, lo más probable es que las acciones de tratamiento y las medidas de seguridad implantadas, que se aplicaron para dar respuesta al riesgo inicial, no cubran los riesgos actuales o no tengan la eficacia y eficiencia apropiadas.

© Universidad Internacional de La Rioja (UNIR)

Para dar respuesta a esta necesidad de actualización, las metodologías de gestión de riesgos contemplan que el proceso en sí debe estar enmarcado en un proceso de **mejora continua,** con una actualización continua, e incluyen una fase de seguimiento y revisión.

La metodología que se escoja debe ser objetiva, fiable, medible y replicable, además, debe permitir la medición continua y estar soportada por una herramienta de gestión.

Metodologías de gestión del riesgo

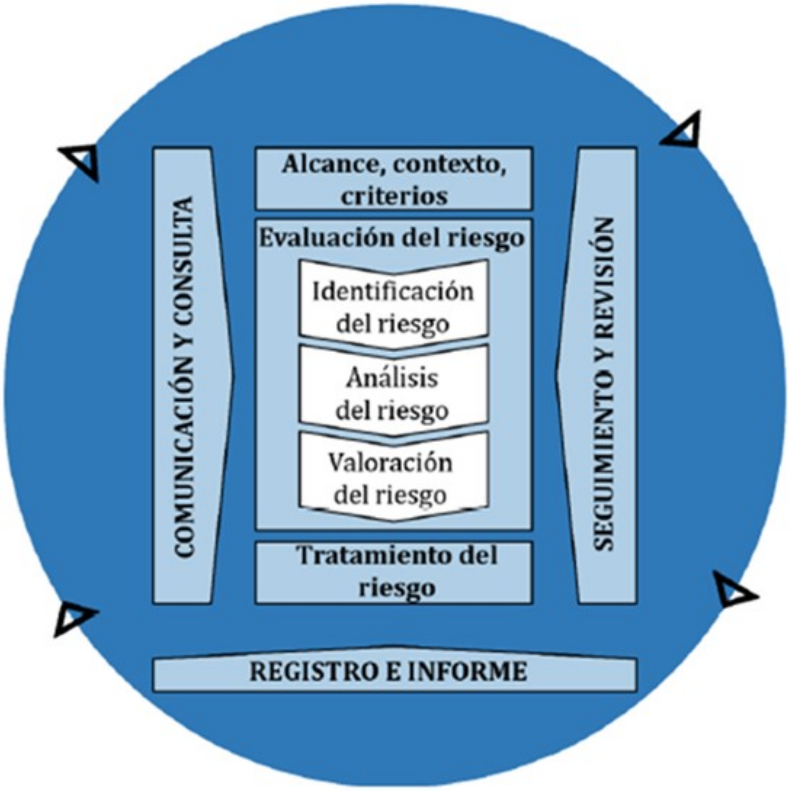


Figura 1. Proceso. Fuente: UNE-ISO 31000:2018 (2018), p. 6.

© Universidad Internacional de La Rioja (UNIR)

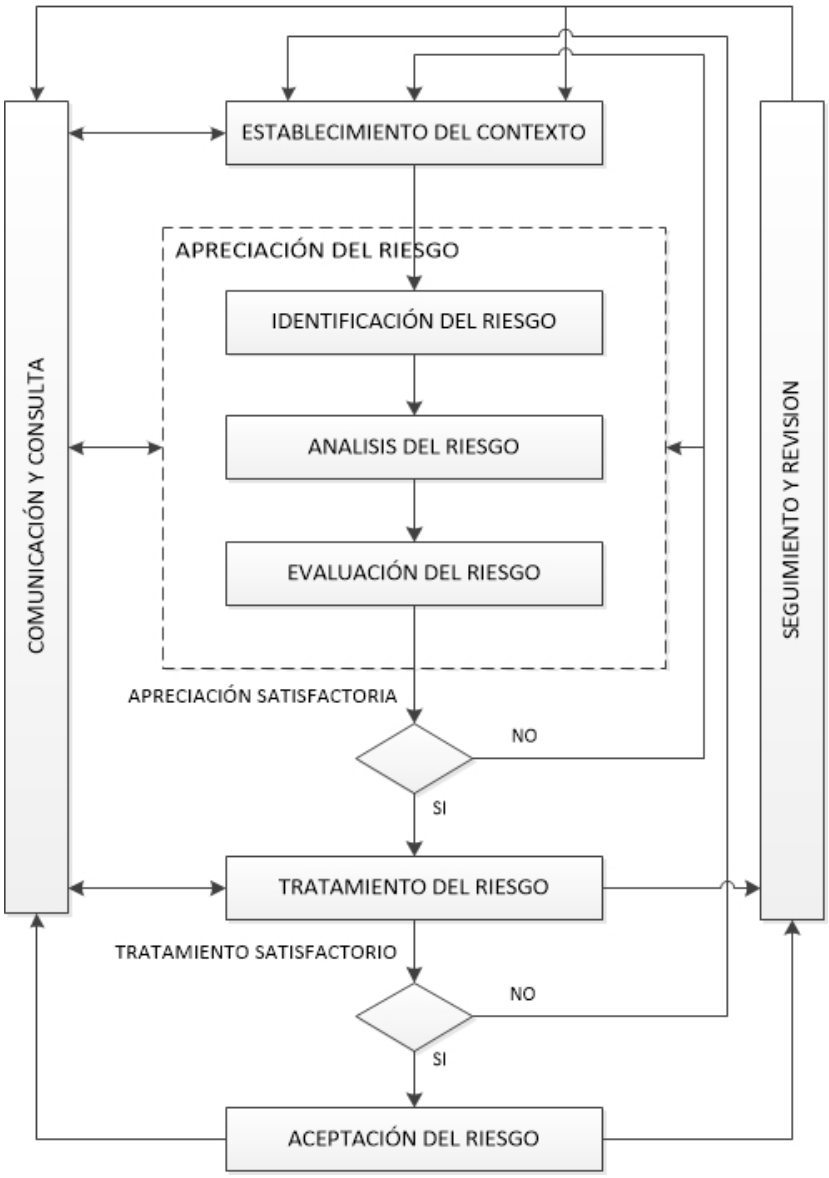


Figura 2. Estructura General de Análisis de Riesgos. Fuente: adaptado de ISO 31000:2009 (2009).

Figura 3. Proceso de evaluación del riesgo. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

9.2. Evaluación de riesgos de las Tecnologías de la Información

Evaluación de riesgos de Tecnologías de la Información

Según la norma ISO 31000, la evaluación del riesgo es un proceso global compuesto de tres **procesos:** identificación del riesgo, análisis del riesgo y valoración del riesgo.

Este proceso de evaluación del riesgo se debe realizar de forma sistemática, iterativa y colaborativa con base en el conocimiento y los puntos de vista aportados por las partes interesadas, cuya participación es imprescindible en este proceso, en el que se debe utilizar la mejor información disponible, la cual debe ser complementada por investigaciones y fuentes adicionales, en el caso de que fuese necesario.

Identificación de riesgos de TI

La identificación del riesgo de TI es el proceso que tiene por objeto **detectar, identificar y registrar los riesgos** a los que está expuesta la información y los sistemas de información y comunicaciones de la organización.

Si consideramos el riesgo como el efecto sobre los objetivos de la incertidumbre existente y tenemos en cuenta que el efecto supone una desviación sobre los previstos y que dicho efecto puede ser positivo o negativo, o incluso tener los dos compontes, estamos hablando de que la existencia del riesgo supone la existencia de oportunidades o de amenazas para la organización. En nuestro caso solo vamos a tratar los riesgos que supongan un efecto negativo de cara a la consecución de los objetivos de la organización, vamos a tratar de riesgos que tengan origen en la materialización de amenazas.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La finalidad de la identificación del riesgo es **identificar los eventos,** las materializaciones de **amenazas** o las situaciones que pudiesen ocurrir y originar un impacto que comprometiese el cumplimiento de los objetivos del sistema o de la organización.

El proceso de identificación del riesgo incluye la identificación de las causas y del origen de las amenazas, eventos, situaciones o circunstancias que pudiesen tener un impacto sobre los objetivos de la organización y la magnitud y naturaleza de dicho impacto.

Para identificar los riesgos, se pueden utilizar:

- Métodos basados en evidencias, como listas de verificación y revisiones de datos históricos.
- Enfoques sistemáticos. Un grupo de expertos utiliza un proceso sistemático para identificar riesgos por medio de un conjunto estructurado de proposiciones o preguntas.
- Técnicas de razonamiento inductivo.

Adicionalmente, se pueden utilizar **técnicas de apoyo,** como pueden ser la tormenta de ideas y el método Delphi, para mejorar la precisión y la exhaustividad de la identificación del riesgo.

Independientemente de las técnicas actuales que se empleen a la hora de identificar el riesgo, es imprescindible que en el proceso de identificación del riesgo se tengan en cuenta los **factores humanos y culturales** y el propio **contexto,** tanto interno como externo, de la organización.

En función del grado de conocimiento de la existencia de un posible riesgo, este se clasifica en:

- **Conocido-Conocido:** el riesgo es perfectamente conocido.

© Universidad Internacional de La Rioja (UNIR)

- **Conocido-Desconocido:** el riesgo se desconoce, pero se sabe que podría existir.
- **Desconocido-Desconocido:** se desconoce todo, incluso la posible existencia del riesgo.

A la hora de identificar los riesgos es necesario tener en cuenta la existencia de riesgos desconocidos.

El valor del riesgo es función de la probabilidad de ocurrencia de un evento, de una materialización de una amenaza, y del impacto que supone dicha materialización sobre el cumplimiento de los objetivos.

La probabilidad de materialización de una amenaza depende de:

- El origen de la amenaza.
- El atacante, en caso de que sea intencionada.
- Las características de la organización: del sistema de información, del activo, del elemento que sea objeto del ataque y de las vulnerabilidades que tenga.

En el caso de un sistema de información, una **vulnerabilidad** es una debilidad o fallo que permite o facilita que un atacante pueda comprometer la integridad, disponibilidad o confidencialidad de la información que procesa, almacena o transmite dicho sistema de información.

Podemos decir, que las amenazas se materializan aprovechando las oportunidades que brindan las vulnerabilidades, cuando más vulnerable sea un sistema más probable es que una amenaza se materialice, que un atacante tenga éxito.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El **impacto** es la **consecuencia de un evento,** la materialización de una amenaza que compromete la integridad, disponibilidad o confidencialidad de la información que procesa, almacena o transmite un sistema de información y que, por lo tanto, afecta de manera negativa a los objetivos de la organización.

El valor del impacto se debe cuantificar y se puede expresar de forma cualitativa o cuantitativa, teniendo en cuenta que el impacto puede incrementarse por la acumulación de eventos o por efectos en cascada.

Una **amenaza emergente** es una amenaza nueva o una amenaza ya existente de la que se ha detectado un incremento del número de materializaciones o cambios en sus características que hacen que aumente el impacto.

Un riesgo se considera emergente cuando la amenaza que lo origina es una amenaza emergente.

El riesgoaumenta cuando:

- El número de amenazas que lo originan aumenta.
- La probabilidad de materialización de la amenaza aumenta.
- El impacto de la materialización de la amenaza aumenta.

Es necesario tratar los riesgos de TI como riesgos emergentes.

Se debe **identificar los riesgos emergentes,** para ello es necesario establecer un proceso específico que se desarrolla por medio de las siguientes actividades:

- Recopilación de datos.
- Análisis de los datos.
- Intercambio de información.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

L a **recopilación de datos** debe ser realizada con el mayor número posible de **fuentes:** de la literatura científica, de los medios de comunicación, de la información proporcionada por los órganos reguladores, de los datos de negocio, de la vigilancia y supervisión de las redes y sistemas y de la opinión de expertos (miembros de paneles, redes de contactos, grupos de interés…).

Los datos obtenidos deben ser filtrados y analizados para detectar señales e indicios de posibles nuevos riesgos.

Por último, el intercambio de información con otras organizaciones y partes interesadas es imprescindible para una detección temprana de los riesgos emergentes y una respuesta eficaz a los mismos.

A la hora de **identificar los riesgos,** entre otras, se pueden utilizar las siguientes **técnicas:**

- Tormenta de ideas.
- Entrevistas estructuradas o semiestructuradas.
- Delphi.
- Listas de verificación.
- Análisis preliminar de peligros.
- Estudios de peligros y de operatividad (HAZOP).
- Análisis de peligros y puntos de control críticos (HACCP).
- Apreciación de riesgos ambientales.
- Estructura «y si…» (SWIFT).
- Análisis de escenarios.

© Universidad Internacional de La Rioja (UNIR)

- Análisis de los modos de fallo y de los efectos.
- Análisis de causa-y-efecto.
- Análisis de fiabilidad humana.
- Mantenimiento centrado en la fiabilidad.
- Matriz de consecuencia/probabilidad.

Análisis de riesgos en TI

El proceso de análisis de riesgos en TI tiene por objeto alcanzar una comprensión de los riesgos en las tecnologías de la información, lo que nos va a proporcionar elementos de entrada tanto para el proceso de valoración del riesgo, y para la toma de decisiones en relación con la necesidad de tratamiento de los riesgos, así como de las estrategias y los métodos de tratamiento del riesgo más apropiados.

El proceso de análisis de riesgos en TI consiste en determinar y evaluar sus **consecuencias,** determinando la probabilidad de ocurrencia de los sucesos de riesgo, materializaciones de amenazas y otros eventos que hayan sido identificados, teniendo en cuenta tanto la presencia o no de los controles, medidas de seguridad, actualmente implantados, así como su eficacia y grado de madurez.

En función de las consecuencias, del impacto y de la probabilidad de ocurrencia se determina el nivel de riesgo.

A la hora de realizar un análisis de riesgos hay que identificar, considerar y tener en cuenta las **causas y** las **fuentes del riesgo,** sus orígenes, las amenazas, los actores, las circunstancias y factores que influyen en la magnitud de las consecuencias, del impacto y la probabilidad de materialización de este. Teniendo en cuenta siempre, que un suceso, una materialización de una amenaza, puede tener múltiples consecuencias y puede afectar a múltiples activos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

A la hora de analizar los riesgos se deben calcular dos valores de riesgo: el primero sin tener en cuenta los controles, las medidas de seguridad, las salvaguardas, actualmente implantados, y el segundo teniéndolos en cuenta, valorando su eficacia y grado de madurez. Lo que nos va a proporcionar dos valores del riesgo:

- **Riesgo inherente,** también denominado riesgo potencial, el riesgo al que se está expuesto sin tener en cuenta los controles implantados: función (Impacto, vulnerabilidad, probabilidad).

- **Riesgo real,** el riesgo al que se está expuesto teniendo en cuenta la eficacia y madurez de los controles implantados: función (Impacto, vulnerabilidad, probabilidad, controles).

Cuando se realiza un análisis de riesgos en TI hay que llevar a cabo una **estimación de** toda la gama de los **posibles impactos** que se podrían derivar de un evento, de la materialización de una amenaza, así como de las probabilidades de ocurrencia tanto del evento como de cada uno de los posibles impactos. Sin embargo, en algunas circunstancias, podemos estimar probabilidades muy bajas, lo que nos podría llevar a desestimar algunos riesgos por insignificantes, aunque su impacto fuese alto. En estos casos debería tener mayor peso el impacto que la probabilidad en el cálculo del valor del riesgo y en la toma de decisiones asociada al tratamiento de estos riesgos insignificantes.

En ocasiones, una consecuencia o un impacto puede ser el resultado de diferentes eventos, de diferentes circunstancias, de diferentes materializaciones de amenazas o de un suceso no identificado. En este caso, de indeterminación del origen, a la hora de analizar los riesgos en TI hay que centrarse en **analizar la criticidad y la vulnerabilidad de los activos,** de los componentes del sistema, para, con base en ellos, **estimar el valor del riesgo** y para poder tomar decisiones respecto al tratamientos del riesgo necesarios, los niveles de protección y las estrategias de recuperación.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Para analizar los riegos en TI se pueden utilizar métodos cualitativos, semicuantitativos, o cuantitativos. El grado de detalle del análisis va a depender del caso particular, de la disponibilidad de datos fiables y de las necesidades de toma de decisiones de la organización. En algunos casos, la legislación aplicable establece el método y el grado de detalle del análisis de riesgos que se deben utilizar a la hora de analizar los riesgos de determinados sistemas de información.

La **apreciación cualitativa** define las consecuencias, la probabilidad y el nivel de riesgo, indicando niveles tales como «alto», «medio» y «bajo», o como «muy alto», «alto», «medio», «bajo» y «muy bajo», y combina las consecuencias y la probabilidad para evaluar el nivel de riesgo resultante en función de criterios cualitativos, utilizando habitualmente tablas para realizar la estimación.

A continuación, se muestra un ejemplo de tabla para el cálculo del riesgo con una apreciación cualitativa.

CÁLCULO DEL RIESGO					
	Probabilidad				
Impacto	MB	B	M	A	MA
MA	B	M	A	MA	MA
A	B	M	A	A	MA
M	MB	B	M	A	A
B	MB	MB	B	M	M
MB	MB	MB	MB	B	B

Tabla 1. Cálculo del riesgo con una apreciación cualitativa. Fuente: elaboración propia.

Los métodos de análisis de riesgos **semicuantitativos** utilizan **escalas de valoración numéricas** para las consecuencias y la probabilidad y las combinan para determinar un nivel de riesgo aplicando una función matemática. Las escalas pueden ser tanto lineales como logarítmicas o tener cualquier otro tipo de relación. y las funciones que también pueden ser muy diferentes. Pero siempre intentar definir criterios objetivos a la hora de efectuar una valoración, como ejemplo se incluyen tres tablas de valoración de impacto, una por cada dimensión de la seguridad de la

© Universidad Internacional de La Rioja (UNIR)

información: integridad, disponibilidad y confidencialidad.

A continuación. se muestra un ejemplo de tabla para el cálculo del riesgo con una apreciación semicuantitativa.

INTEGRIDAD	
5	▸ Imprescindible para prestar el servicio. ▸ No hay activo alternativo y tiene difícil sustitución.
4	▸ Imprescindible para prestar el servicio. ▸ Hay alternativa, pero no cubre todas las necesidades. ▸ El tiempo de reposición es alto.
3	▸ Imprescindible para prestar el servicio. ▸ Hay alternativa completa o la sustitución es relativamente sencilla.
2	▸ El servicio puede prestarse a pesar de la perdida de integridad, aunque con deficiencias. ▸ Hay alternativas y a sustitución es sencilla.
1	▸ El servicio se ve escasamente afectado a pesar de la pérdida de integridad.
0	▸ La degradación del activo no afecta al servicio.
DISPONIBILIDAD	
5	▸ El activo es imprescindible para prestar el servicio. ▸ No hay activo alternativo y tiene difícil sustitución.
4	▸ El activo es imprescindible para prestar el servicio. ▸ Hay alternativa, pero no cubre todas las necesidades. ▸ El tiempo de reposición es alto.
3	▸ El activo es imprescindible para prestar el servicio. ▸ Hay alternativa completa o la sustitución es relativamente sencilla.
2	▸ El servicio puede prestarse a pesar de la degradación del activo, aunque con deficiencias. ▸ Hay alternativas y a sustitución es sencilla.
1	▸ El servicio se ve escasamente afectado a pesar de la degradación del activo.
0	▸ La degradación del activo no afecta al servicio.

© Universidad Internacional de La Rioja (UNIR)

CONFIDENCIALIDAD	
5	▸ Consecuencias muy graves con impacto económico y legal.
4	▸ Consecuencias muy graves con impacto económico.
3	▸ Consecuencias graves con impacto económico y legal.
2	▸ Consecuencias graves con impacto económico.
1	▸ Impacto económico leve
0	▸ Sin consecuencias.

Tabla 2. Cálculo del riesgo con una apreciación cuantitativa. Fuente: elaboración propia.

Para realizar un **análisis cuantitativo** es necesario estimar valores reales para las consecuencias y sus probabilidades, para poder obtener valores del nivel de riesgo en unidades específicas, generalmente económicas, que se deben establecer al inicio del proceso de gestión del riesgo en el momento en el que establece el contexto.

En ocasiones no es posible o deseable realizar un análisis cuantitativo completo ya sea debido a que no se dispone de suficiente información acerca del sistema o actividad que se está analizando. Esto puede ser debido, tanto a que no está garantizado que se pueda obtener un resultado válido del análisis cuantitativo como a la falta de datos, a la influencia de factores humanos u otro tipo de factores. En este caso, puede ser más efectiva una valoración semicuantitativa o cualitativa de los riesgos llevada a cabo por personas con conocimientos específicos de los riesgos y activos objeto del análisis.

Cuando se utilicen métodos de análisis cualitativos o semicuantitativos, al inicio del proceso de gestión del riesgo, en el momento en el que establece el contexto del proceso de gestión del se deben establecer y registrar las bases y criterios utilizados

© Universidad Internacional de La Rioja (UNIR)

para la valoración, y definir con claridad todos los términos que se vayan a emplear durante el análisis.

En cualquier caso, incluso cuando se haya aplicado un método cuantitativo de análisis durante todo el proceso de gestión de riesgos, es necesario ser conscientes de que todos los niveles de riesgo calculados son estimativos.

A la hora de **informar el resultado** del análisis de riesgos es necesario determinar y dejar constancia del nivel de exactitud y **precisión** de los valores de riesgo calculado, teniendo en cuenta que estos valores deben ser coherentes con la precisión de los datos y métodos empleados a la hora de efectuar el análisis.

A la hora de **analizar los riesgos,** entre otras, se pueden utilizar las siguientes **técnicas:**

- Estudios de peligros y de operatividad (HAZOP).
- Análisis de peligros y puntos de control críticos (HACCP).
- Apreciación de riesgos ambientales.
- Estructura «y si…» (SWIFT).
- Análisis de escenario.
- Análisis del impacto económico.
- Análisis de la causa primordial.
- Análisis de los modos de fallo y de los efectos.
- Análisis del árbol de fallos.
- Análisis del árbol de sucesos.
- Análisis de causa y consecuencia.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Análisis de causa y efecto
- Análisis de capas de protección (LOPA).
- Diagrama de decisiones.
- Análisis de fiabilidad humana.
- Análisis de pajarita.
- Mantenimiento centrado en la fiabilidad.
- Análisis de Markov.
- Redes Bayesianas.
- Curvas FN.
- Índices de riesgo.
- Matriz de consecuencia y probabilidad.
- Análisis de costes y beneficios.
- Análisis de decisión multicriterio (MCDA).

Los niveles de riesgo se deben definir, calcular y comunicar en los términos más adecuados para cada tipo de riesgo en cuestión, en un lenguaje entendible por el negocio, de forma que sea una ayuda efectiva a hora de la toma de decisiones. Una forma de hacerlo es establecer la magnitud de un riesgo como una distribución de probabilidad sobre un conjunto de impactos.

A continuación, podemos ver un gráfico donde se representan el riesgo como una **distribución de probabilidad e impacto.**

© Universidad Internacional de La Rioja (UNIR)

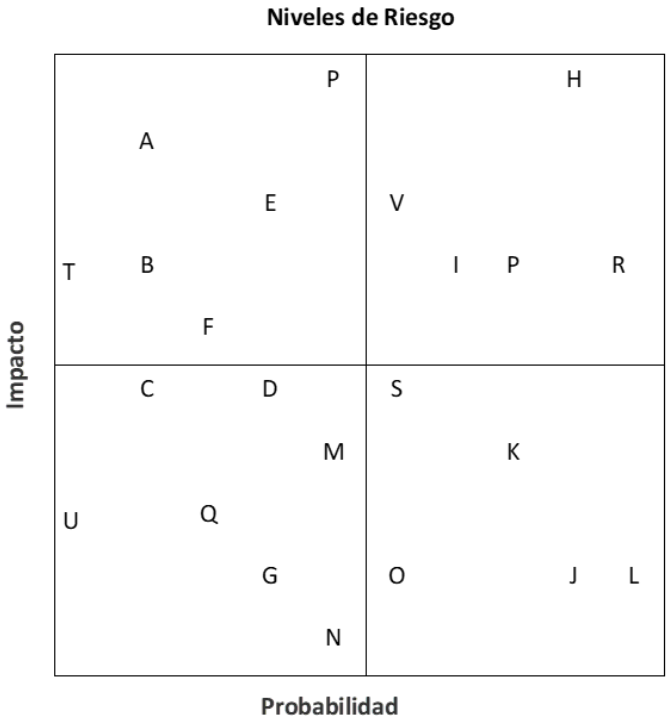


Figura 4. Distribución de probabilidad e impacto de los niveles de riesgo. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

9.3. Referencias bibliográficas

International Organization for Standardization. (2009). *Risk management — Principles and guidelines* (estándar ISO/IEC 31000:2009). https://www.iso.org/standard/43170.html

International Organization for Standardization. (2018). Risk management — Principles and guidelines (estándar ISO/IEC 31000:2018). www.iso.org/standard/65694.html

© Universidad Internacional de La Rioja (UNIR)

Modelado de amenazas, una técnica de análisis y gestión de riesgo asociado a software y aplicaciones

Barba Olivares, G. (2017). *Modelado de amenazas, una técnica de análisis y gestión de riesgo asociado a software y aplicaciones* [Especialización en Seguridad Informática]. Universidad Piloto de Colombia. http://repository.unipiloto.edu.co/handle/20.500.12277/2646

El presente documento describe la técnica de análisis y gestión de riesgo modelado de amenazas, la cual se asocia con el entorno de desarrollo, software seguro y aplicaciones.

© Universidad Internacional de La Rioja (UNIR)

Caso práctico sobre apetito del riesgo

Carlos Muñoz Vega, C. y Gil Aldea, T. (Coord.). (2015). Caso práctico sobre apetito del riesgo. https://auditoresinternos.es/uploads/media_items/150629-caso-pr%C3%A1ctico-sobre-apetito-de-riesgo.original.pdf

Esta guía, a través de un caso práctico, ilustra sencilla y exhaustivamente los conceptos principales, distintas utilizaciones, metodologías de cálculo y propuestas sobre cómo determinar el apetito del riesgo en una organización.

© Universidad Internacional de La Rioja (UNIR)

Patrones de Ataque y de Seguridad como guía en el desarrollo de software

Ramos, I. (2015). *Patrones de Ataque y de Seguridad como guía en el desarrollo de software* [18° Concurso de Trabajos Estudiantiles]. Universidad Tecnológica Nacional. https://44jaiio.sadio.org.ar/sites/default/files/est256-265.pdf

Dado un conjunto bien definido de patrones de seguridad, ¿son estos adecuados para repeler o mitigar un conjunto concordante de patrones de ataque? Mediante un recorrido cronológico sobre la investigación desarrollada en materia de seguridad, previa y presente, se va a introducir cada concepto asociado a esta pregunta así como la importancia del tratamiento de esta información —su catalogación—, las dificultades que presentan a la hora de llevarse a la práctica y los avances que se están haciendo respecto de esto último.

© Universidad Internacional de La Rioja (UNIR)

Amenazas Persistentes Avanzadas

Villalón Huerta, A. (2016). *Amenazas Persistentes Avanzadas.* Naulibres.

En este documento, escrito desde la perspectiva de seguridad defensiva en términos generales (aunque hay casos en los que se aplica el rol del atacante, algo que puede deducirse fácilmente por el contexto), se tratan de exponer desde los principales actores que juegan en el terreno del robo de información hasta las aproximaciones de defensa frente a los mismos, pasando por las tácticas, técnicas y procedimientos que en uno y otro lado aplicaremos. Todo ello enmarcado, o al menos tratado de enmarcar, en eso que llamamos ciberinteligencia, esa palabra tan de moda.

© Universidad Internacional de La Rioja (UNIR)

Test

1. ¿Cuál de las siguientes afirmaciones es correcta?:

A. El riesgo potencial es el riesgo al que se está expuesto teniendo en cuenta la eficacia y madurez de los controles implantados.

B. El riesgo real es el riesgo al que se está expuesto sin tener en cuenta los controles implantados.

C. El riesgo inherente es el riesgo al que se está expuesto teniendo en cuenta la eficacia y madurez de los controles implantados.

D. El riesgo real es el riesgo al que se está expuesto teniendo en cuenta la eficacia y madurez de los controles implantados.

2. ¿Cuál de las siguientes afirmaciones es correcta?

A. Para realizar un análisis semicuantitativo es necesario estimar valores reales para las consecuencias y sus probabilidades.

B. Para realizar un análisis cuantitativo no es necesario estimar valores para las consecuencias y sus probabilidades.

C. Para realizar un análisis cualitativo es necesario estimar valores reales para las consecuencias y sus probabilidades.

D. Para realizar un análisis cuantitativo es necesario estimar valores reales para las consecuencias y sus probabilidades.

3. A la hora de identificar los riesgos, ¿cuál de las siguientes no es una técnica valida?

A. Análisis de escenarios.

B. Tormenta de ideas.

C. Análisis de Markov.

D. Análisis de fiabilidad humana.

© Universidad Internacional de La Rioja (UNIR)

4. Respecto al tratamiento del riesgo, ¿cuál de las siguientes afirmaciones es correcta?

A. Hay dos formas básicas de compartir riesgo: financiando y transfiriendo.

B. Para mitigar el riesgo existen tres opciones.

C. La eliminación de la fuente de riesgo es una opción frente a un riesgo que no es aceptable.

D. Solo se comparte el riesgo cualitativo.

5. A la hora de analizar los riesgos, cuál de las siguientes no es una técnica válida:

A. Tormenta de ideas.

B. Análisis de Markov.

C. Análisis de escenarios.

D. Análisis del árbol de fallos.

6. De acuerdo con su forma de actuación, las salvaguardas se pueden clasificar en:

A. Preventivas y adaptativas.

B. Preventivas y correctivas.

C. Anticipativas y reactivas.

D. Preventivas y reactivas.

7. Cuál de las siguientes afirmaciones es incorrecta:

A. El valor del impacto se debe cuantificar y se puede expresar de forma cualitativa o cuantitativa.

B. El riesgo aumenta cuando la probabilidad de materialización de la amenaza aumenta.

C. El impacto puede incrementarse por acumulación de eventos.

D. El impacto es independiente del número de eventos.

© Universidad Internacional de La Rioja (UNIR)

8. ¿Cuál de las siguientes no es una clasificación de tipo de riesgos?:

A. Conocido-Conocido.

B. Conocido-Desconocido.

C. Desconocido-Desconocido.

D. Desconocido-Conocido.

9. Cuando en función del grado de conocimiento de la existencia de un posible riesgo este se clasifica como Conocido – Desconocido, significa que:

A. El riesgo es perfectamente conocido.

B. El riesgo se desconoce, pero se sabe que podría existir.

C. Se desconoce todo incluso la posible existencia del riesgo.

D. El riesgo se conoce, pero nunca ha ocurrido.

10. A la hora de analizar los riesgos, cuál de las siguientes no es una técnica válida:

A. Listas de verificación.

B. Estructura «y si...» (SWIFT).

C. Análisis de peligros y puntos de control críticos (HACCP).

D. Análisis de causa y efecto.

© Universidad Internacional de La Rioja (UNIR)